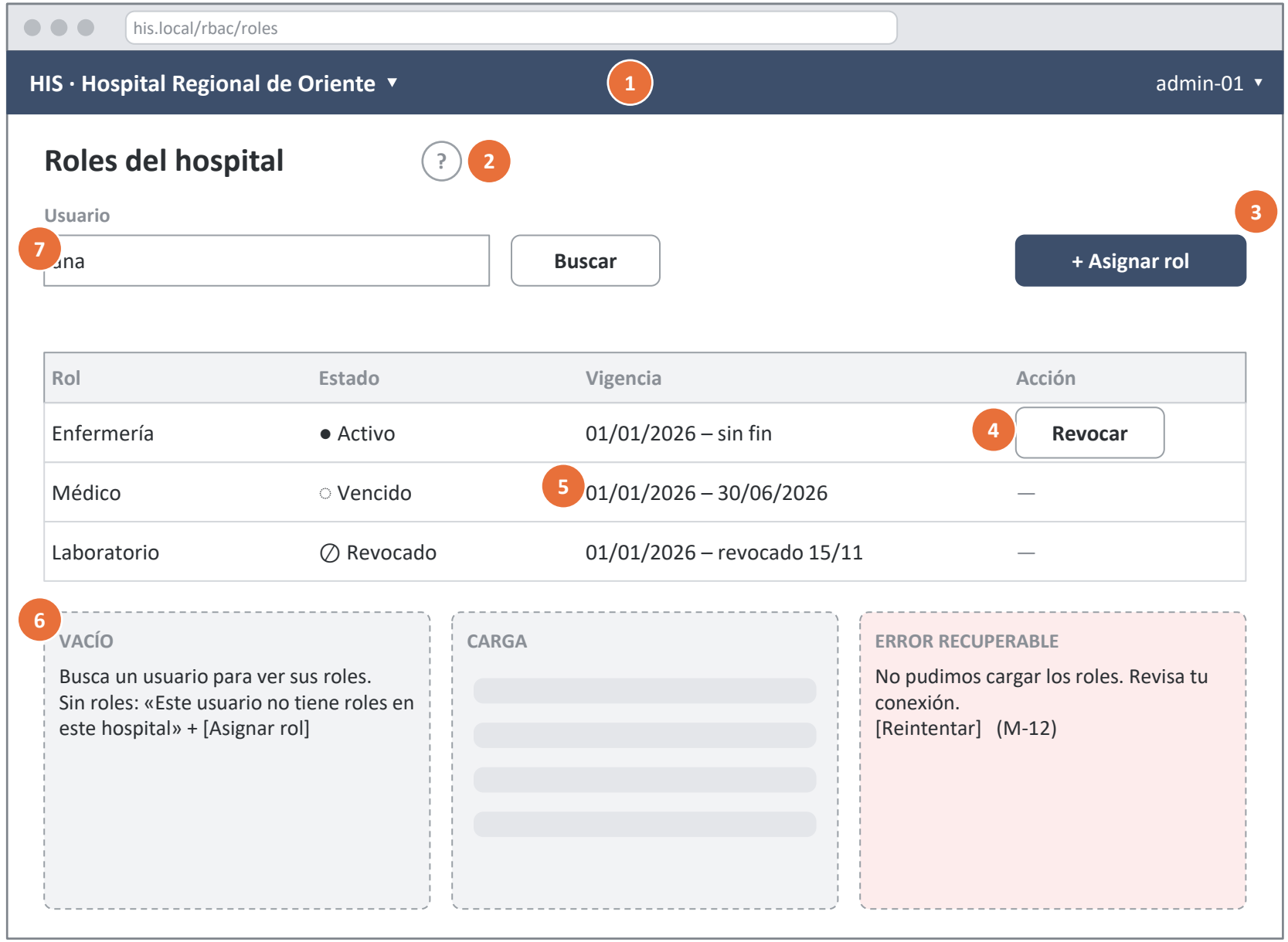
W1 · Roles del hospital — Administrador (roles.asignar / roles.revocar)



Anotaciones

1 · DATOS

Hospital activo siempre visible. Cambiarlo borra la caché de permisos y la tabla: evita operar sobre otro hospital.

2 · AYUDA

«?» explica: un rol da permisos solo en este hospital y solo durante su vigencia.

3 · INTERACCIÓN

«+ Asignar rol» aparece solo si el PDP permite roles.asignar (SiPermiso). Oculto no es protegido: el servidor vuelve a decidir.

4 · INTERACCIÓN

«Revocar» solo en filas activas, con roles.revocar, y nunca en las filas propias (autorrevocación).

5 · ESTADO

Estado de la membresía con icono + texto, no solo color: Activo, Vencido, Revocado.

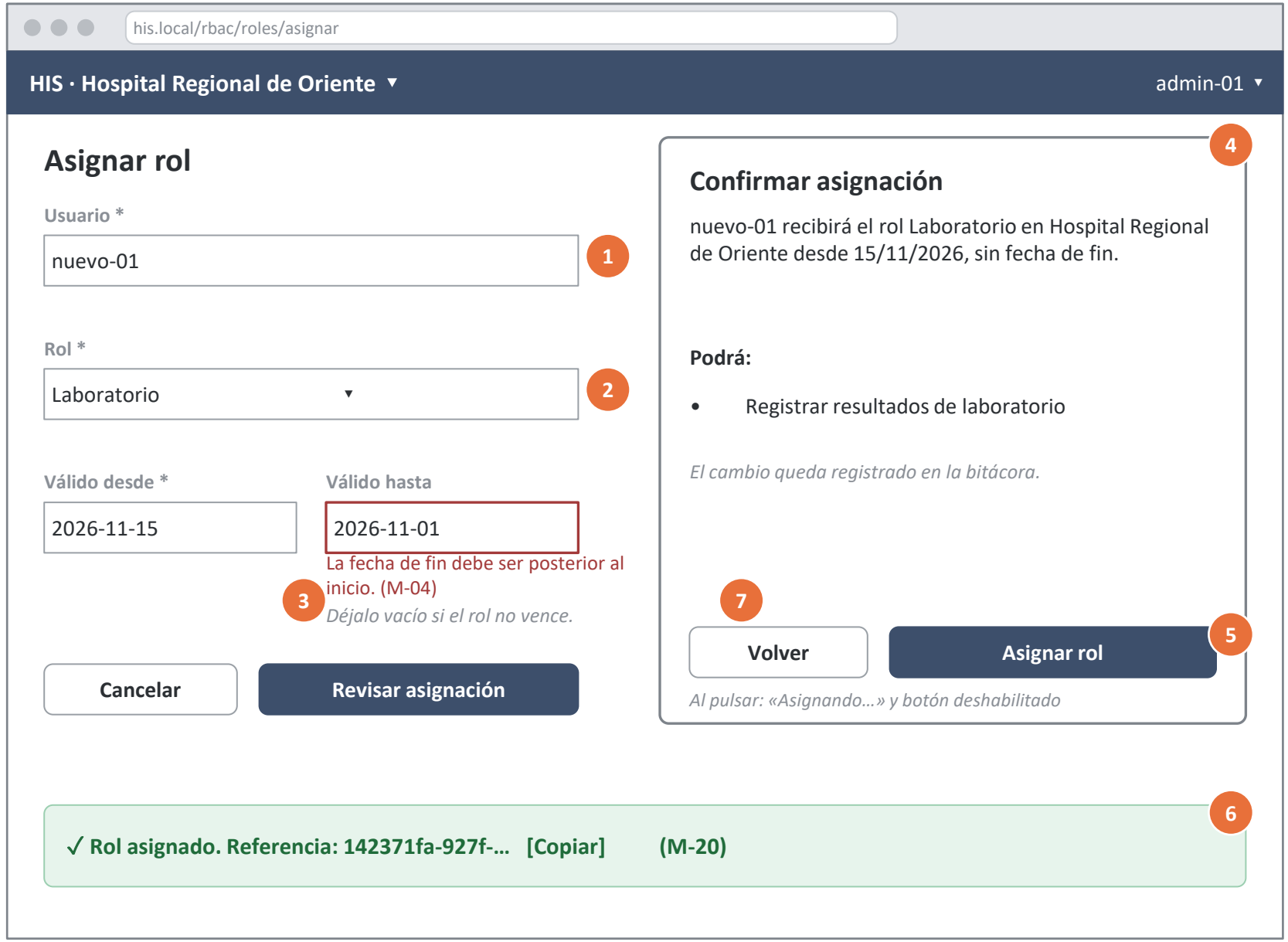
6 · ESTADO

Vacío con instrucción · carga con esqueleto · error recuperable con «Reintentar» (M-12).

7 · BRECHA

Listar las membresías de un usuario necesita GET /api/v1/roles/membresias: no existe en el contrato v1.1.0.

W2 · Asignar rol — formulario, confirmación y éxito



Anotaciones

1 **VALIDACIÓN**

Formato en el cliente con las reglas del servidor: obligatorios, fecha ISO. El error va junto al campo y se conserva lo escrito (M-01).

2 **VALIDACIÓN**

Rol elegido de una lista (catálogo), no texto libre: evita ROL_INVALIDO.

3 **MENSAJE**

Fin > inicio (M-04). Errores del servidor también junto al campo: 404 usuario (M-02), 409 ya lo tiene (M-03), 422 inactivo (M-05).

4 **DECISIÓN**

Confirmación con los permisos que obtendrá: decisión informada antes de enviar.

5 **INTERACCIÓN**

Al enviar: botón deshabilitado + «Asignando…» (evita doble envío). «Volver» y Esc no pierden datos.

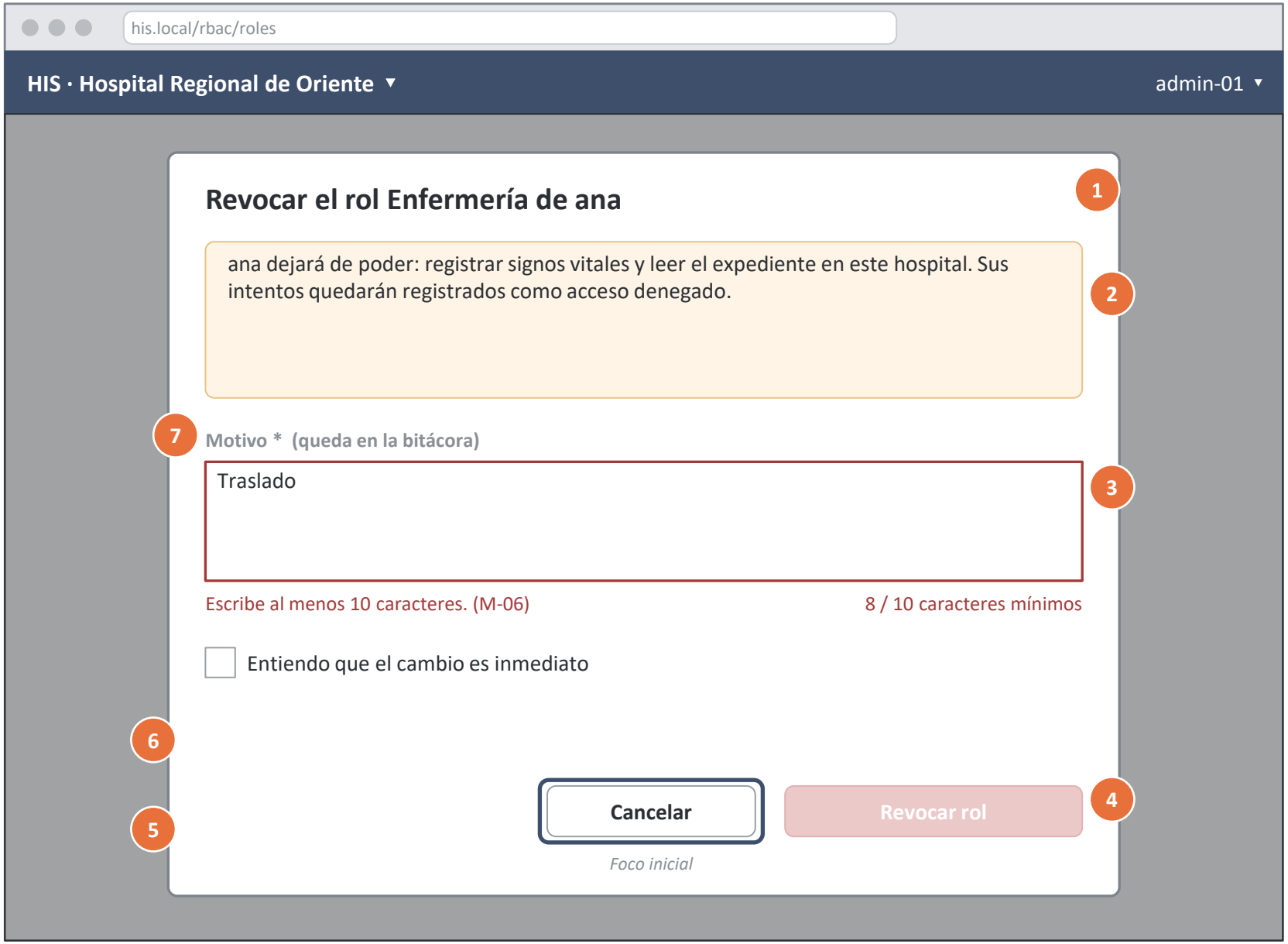
6 **ÉXITO**

Aviso con referencia copiable (M-20). La tabla W1 se actualiza y el foco vuelve a ella.

7 **AYUDA**

Pista bajo «Válido hasta»: «Déjalo vacío si el rol no vence».

W3 · Revocar rol — diálogo de confirmación (acción destructiva)



Anotaciones

1 **DECISIÓN**

Título con el rol y el usuario exactos: no hay duda sobre qué se revoca.

2 **MENSAJE**

Consecuencias en lenguaje claro: qué perderá y que sus intentos quedarán auditados.

3 **VALIDACIÓN**

Motivo con contador en vivo (≥ 10). La regla real está en el Dominio (MOTIVO_INSUFICIENTE).

4 **INTERACCIÓN**

Acción destructiva: botón rojo deshabilitado hasta motivo válido + casilla. Foco inicial en «Cancelar»; Esc cierra.

5 **ÉXITO**

«Rol revocado» + referencia (M-21). La fila pasa a «Revocado» sin recargar la página.

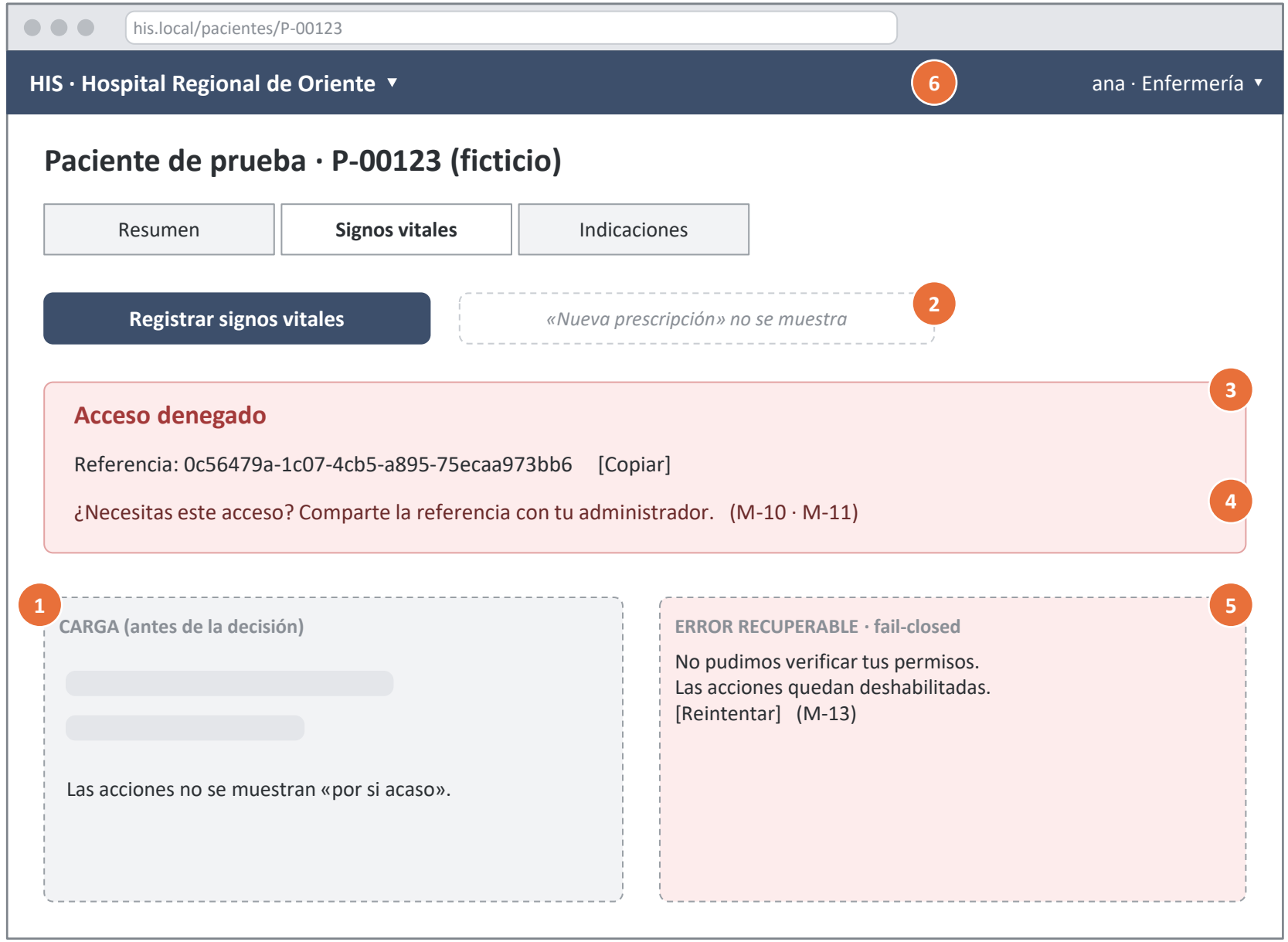
6 **ERROR RECUPERABLE**

404 (otro admin ya lo revocó): M-07 y la lista se recarga, sin perder la búsqueda.

7 **DATOS**

El motivo solo lo ve quien tiene auditoria.consultar; no se muestra al usuario afectado.

W4 · Ficha de paciente — operación protegida (usuario clínico: enfermería)



Anotaciones

1 **ESTADO**

CARGA: acciones como esqueleto hasta que el PDP responde. Nunca se muestran «por si acaso».

2 **INTERACCIÓN**

Solo aparecen las acciones permitidas (usePermiso / SiPermiso). Enfermería no ve «Nueva prescripción».

3 **MENSAJE**

403: «Acceso denegado» + referencia copiable (M-10). Sin rol, sin permiso, sin motivo (R-08).

4 **AYUDA**

Qué hacer después: compartir la referencia con el administrador (M-11).

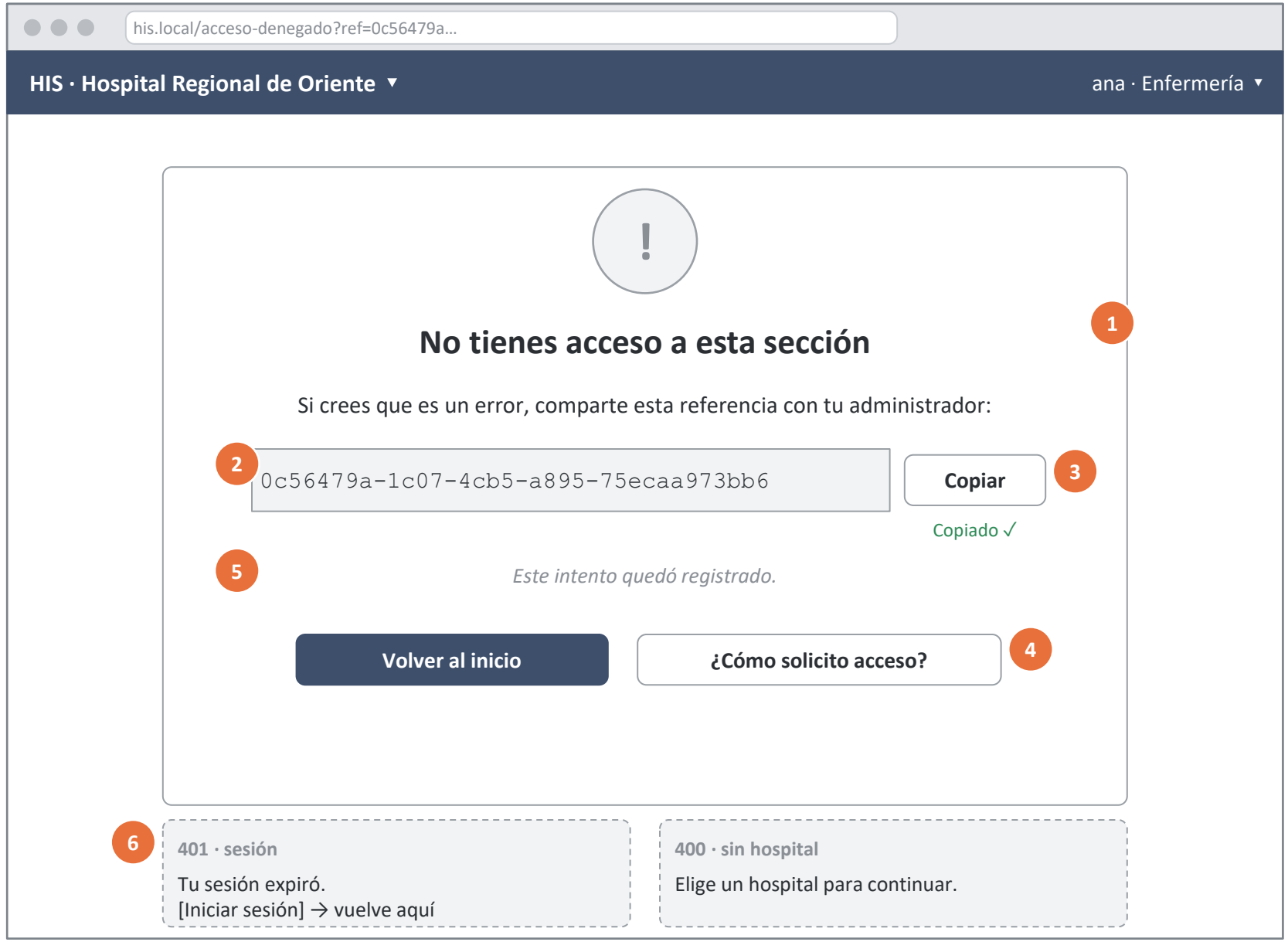
5 **ERROR RECUPERABLE**

PDP no disponible: acciones deshabilitadas (fail-closed) + «Reintentar» (M-13).

6 **DATOS**

Rol visible para el propio usuario. La decisión solo vive 30 s en memoria y se borra al cerrar sesión o cambiar de hospital.

W5 · Acceso denegado — página de ruta protegida (cualquier rol)



Anotaciones

1 **MENSAJE**

Genérico y en lenguaje claro. No dice qué permiso falta ni qué rol tiene el usuario (R-08).

2 **DATOS**

Solo la referencia (correlation_id): útil para el auditor, no revela nada a terceros. Ningún token en la URL.

3 **INTERACCIÓN**

Copiar con un clic; confirma «Copiado ✓» y lo anuncia a lectores de pantalla (aria-live).

4 **AYUDA**

«¿Cómo solicito acceso?» abre la guía: a quién pedirlo y qué referencia dar.

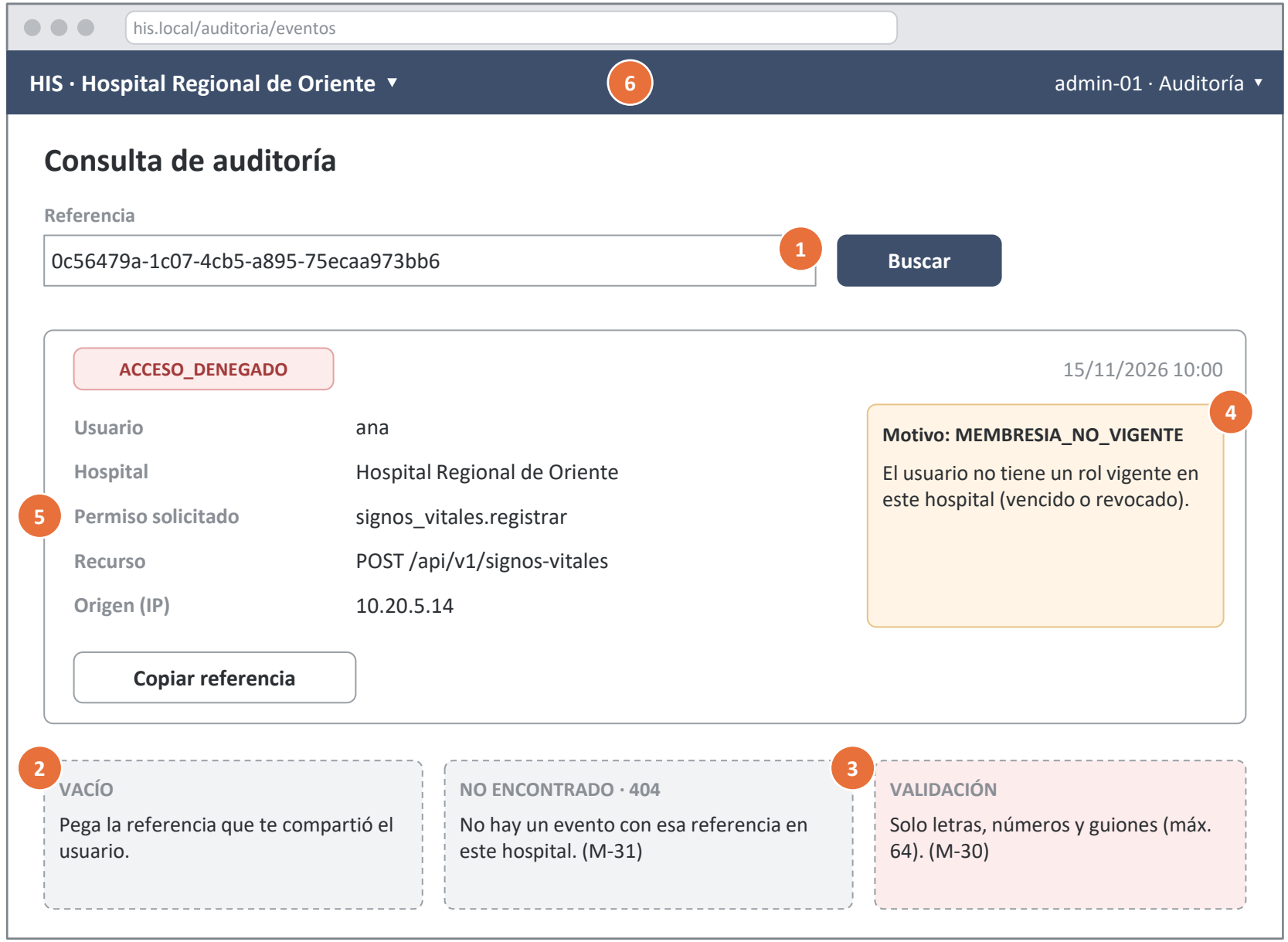
5 **MENSAJE**

Transparencia: el usuario sabe que el intento quedó registrado.

6 **ESTADO**

Variantes: 401 → iniciar sesión y volver al mismo destino (M-14); 400 → elegir hospital (M-15).

W6 · Consulta de auditoría — auditor (auditoria.consultar)



Anotaciones

1 **VALIDACIÓN**
Formato antes de enviar: letras, números y guiones, máx. 64 (M-30). No se envía una consulta inválida.

2 **ESTADO**
Vacío con instrucción · carga · evento encontrado · no encontrado (M-31).

3 **DATOS**
El 404 es idéntico si el evento es de otro hospital: no confirma que exista (aislamiento por tenant).

4 **AYUDA**
Motivo técnico + explicación en lenguaje claro (glosario de motivos).

5 **DATOS**
Solo metadatos del acceso: ningún dato clínico del paciente. Vista de solo lectura.

6 **INTERACCIÓN**
Ruta protegida por auditoria.consultar; sin permiso → W5.